

GZ: 2024-0.671.673 dated October 7, 2024 (Case Number: DSB-D550.1092)

[Note from the editor: Names and companies, legal forms and product designations, addresses (including URLs, IP and email addresses), file numbers (and the like), statistical information, etc., as well as their initials and abbreviations may have been abbreviated and/or altered for pseudonymization reasons. Obvious spelling, grammar, and punctuation errors have been corrected.]

Criminal Finding

Accused legal entity: B*** GmbH (FN *5*0*1k)

The accused legal entity based in **** I***tal, J***straße *2 (hereinafter referred to as "B***"), has, as the responsible party within the meaning of Art. 4 No. 7 of Regulation (EU) 2016/679 on the protection of natural persons in the processing of personal data, on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation, hereinafter: "GDPR"), OJ No. L 119 of May 4, 2016, p. 1 as amended, committed the following administrative offense by realizing the following facts:

B*** has, in its role as the responsible party according to Art. 4 No. 7 GDPR, violated its obligation to cooperate with the Data Protection Authority (as the competent supervisory authority) pursuant to Art. 31 GDPR during the period from December 18, 2023, to September 13, 2024, by failing to respond to the following requests for comments in the context of the data breach procedure under GZ:

D084.4838:

- December 18, 2023: Notification, request for a supplementary report (GZ: D084.4838 – 2023-0.897.054) via email to "info@b***.at" (read confirmation dated December 18, 2023);
- March 15, 2024: Request for a supplementary report (GZ: D084.4838 – 2024-0.150.102) sent via registered mail to "J***straße *2, **** I***tal", delivered on March 20, 2024.

As a result, B***, as the responsible party, did not cooperate with the request of a supervisory authority in fulfilling its duties.

Only after the administrative fine procedure was initiated and the accused was requested to justify itself did the accused submit a statement regarding the above-mentioned data breach procedure via email on September 13, 2024.

The accused legal entity has therefore ultimately violated the following provision of the GDPR:

- The obligation of responsible parties to cooperate with the Data Protection Authority upon request in the fulfillment of their duties according to Art. 31 GDPR.

Administrative offense according to:

Art. 31 in conjunction with Art. 83 para. 1 and 4 lit. a GDPR OJ L 2016/119, p. 1, as amended.

Due to this administrative offense, the following penalty is imposed in accordance with Art. 83 GDPR:

Fine of Euro

According to

€ 600,-

Art. 83 para. 3 and 4 lit. a GDPR OJ L 2016/119, p. 1, as amended.

Furthermore, you are required to pay according to § 64 of the Administrative Penal Act 1991 – VStG: Euro as a contribution to the costs of the penal proceedings, which is 10% of the fine, but at least 10 Euro;

Euro as reimbursement of cash expenses for

The total amount to be paid (fine/costs/cash expenses) therefore amounts to

Euro

Payment deadline:

If no appeal is filed, this criminal finding is immediately enforceable. In this case, the total amount must be paid within two weeks after the legal force occurs to the account [here abbreviated] in the name of the Data Protection Authority. Please indicate the business number and the date of completion as the purpose of use.

If payment is not made within this period, the total amount may be collected. In this case, a flat-rate cost contribution of five Euro must be paid. If payment is still not made, the outstanding amount will be enforced.

Justification:

1.

The following decision-relevant facts are established based on the conducted evidentiary proceedings:

1.1.

Regarding the course of the data breach procedure prior to the first criminal finding (D550.829) Mr. Sebastian W*** (Managing Director of B*** - hereinafter "GF") submitted a data breach notification pursuant to Art. 33 GDPR to the Data Protection Authority (hereinafter "DSB") on April 24, 2023, via email on behalf of B***. An informal form provided by the DSB on its website was used for the notification.

In the course of this notification, the GF informed the DSB that on March 6, 2023, there was a "ransomware attack" by unknown persons, resulting in data being encrypted. Furthermore, the GF stated that it was not known whether "theft" had occurred and that "data leakage" was not evident.
60,-

660,-

As a category of affected persons, the Managing Director (GF) indicated "employees" and quantified the number of affected individuals as "55." As affected categories of personal data, the GF specified "confirmations, payroll documents." Regarding the measures taken to remedy the breach of personal data protection, the GF stated: "The entire network was disconnected from the internet. Systems are currently being rebuilt and hardened." Concerning the measures taken to mitigate potential adverse effects, the GF indicated: "Encrypted hard drives of the system were securely deleted." At the time of the security breach, the GF reported the date as March 6, 2023 (approximately 5:45 PM). At the time of becoming aware of the security incident, the GF reported the date as March 6, 2023 (approximately 6:30 PM). Regarding the delayed notification, the GF argued that they assumed "a corresponding report was automatically forwarded" due to a police report.

In response to this notification, the Data Protection Authority (DSB) initiated a security breach procedure under reference number D084.4838. Based on the information provided by the GF in the notification dated April 24, 2023, the DSB could not make a conclusive assessment of the case and requested additional information from B*** (via email to info@b***.at, attention GF) in a letter dated April 24, 2023 (reference number D084.4838 - 2023-0.309.559).

The GF then responded via email on April 26, 2023, as follows (formatting not reproduced 1:1):

"Dear Data Protection Authority,

Thank you for the email.

We have and will not inform our guests about this as we do not want to unnecessarily burden them with such sick incidents... we are a consciousness and radiate only pure love [Note from the editor: Special characters removed for display reasons.] and good mood.

Since we know that thoughts and actions create matter, nothing bad will happen.

We know that it will be so!!!

We have, of course, made arrangements with the company k*** security to prevent such incidents in the future.

We only made this notification so that our insurance is satisfied and we can get the damage reimbursed.

I kindly ask you to let this incident rest with this email and am available for further questions by phone at 0043***3*5*7*4.

With warm regards from B***,

Sebastian W***

www.b***.at"

In response, a further request for additional information was sent to B*** in a letter dated April 26, 2023 (reference number D084.4838 - 2023-0.316.639). B*** then responded with a blank notification via email on April 27, 2023, attaching the previously submitted statement from the GF dated April 26, 2023.

1.2.

Regarding the course of the first administrative fine procedure under reference number D550.829 The DSB subsequently initiated an administrative fine procedure against B*** and requested justification from them and their managing directors in a letter dated June 5, 2023. The request for justification (hereinafter "AzR") was sent via registered mail and received by the GF on June 9, 2023.

No justification was submitted to the DSB in response to the AzR. B*** did not participate in the administrative fine procedure and also did not submit any statement in the security breach procedure after the initiation of the administrative fine procedure. On December 12, 2023, the DSB imposed an (initial) penalty decision on B*** (D550.829 – 2023-0.603.142) due to the violation of the duty to cooperate in the aforementioned security breach procedure concerning a specific period of offense. This decision became final due to the lack of legal remedies and was enforced through compulsory measures (reference number D560.829 – Reminder and enforcement procedure for the first penalty decision).

1.3.

Regarding the further course of the security breach procedure (D084.4838)

After the conclusion of the administrative fine procedure through the aforementioned (initial) penalty decision, the DSB continued the security breach procedure under reference number D084.4838 and requested B*** in a letter dated December 18, 2023 (D084.4838 – 2023-0.897.054) to provide additional information (via email to "info@b***.at"). On the same day, the DSB received a read confirmation; however, no response was forthcoming.

For this reason, the DSB again requested B*** to provide additional information via registered letter dated March 15, 2024 (D084.4838 – 2024-0.150.102). The letter was delivered to B*** on March 20, 2023. However, B*** continued to remain unresponsive.

1.4.

Regarding the course of the present administrative fine procedure

The DSB subsequently initiated another administrative fine procedure against B*** and requested justification from them in a letter dated August 2, 2024. The AzR was sent via registered mail and delivered on August 6, 2024.

On August 28, 2024, a letter from the legal representative of B*** was received, requesting the transmission of the file contents from the security breach procedure as well as the present administrative fine procedure. Furthermore, it was requested that the deadline for justification be extended by two weeks from the transmission of the file contents.

The DSB fully complied with this request in a decision dated August 29, 2024.

On September 13, 2024, the legal representation of B*** submitted their justification. The content initially explained the events surrounding the security breach of March 6, 2023, step by step. Subsequently, the questions to which B*** had been repeatedly requested to respond in the context of the security breach proceedings were also addressed. However, B*** did not disclose the annual revenue achieved worldwide in the previous year. The questions regarding the security breach proceedings that have now been answered were forwarded to the responsible caseworker, and the proceedings under file number D084.4838 could ultimately be concluded.

2.

The findings are made based on the following assessment of evidence:

2.1.

It should be noted at the outset that B*** did not present any submissions during the investigation proceedings, specifically after being requested to provide justification, that would contradict the findings made above. The procedural course regarding the aforementioned proceedings is known to the accused. The justification submitted in the relevant administrative penalty proceedings is essentially a statement regarding the security breach proceedings. No submission concerning the newly initiated administrative penalty proceedings was made.

2.2.

The findings in 1.1 undoubtedly arise from the administrative act concerning the security breach proceedings (file number D084.4838).

2.3.

The findings in 1.2 undoubtedly arise from the administrative penalty file in which the first penalty decision against B*** was imposed (file number D550.829) as well as from the reminder and enforcement file (file number D560.829).

2.4.

The findings in 1.3 are also based on the administrative act concerning the security breach proceedings (file number D084.4838), but on those document components that were created after the conclusion of the first administrative penalty proceedings.

2.5.

The findings in 1.4 are based on the relevant administrative penalty file and were not disputed by the accused legal entity.

2.6.

The revenue of the accused could not be determined due to their lack of cooperation. No documents were submitted in this regard. The accused was requested to disclose their revenue as part of the request for justification. The accused did not comply with this request during the investigation proceedings. The Data Protection Authority ultimately conducted an official inquiry within the company register (company register excerpt/annual financial statement) and examined the available documents. Specifically, while the annual financial statement of the accused as of November 30, 2023, can be viewed in the company register, this document does not contain an excerpt of the profit and loss statement of the accused or any other specific information regarding the revenue generated.

3.

Legally, it follows:

3.1.

On the Jurisdiction of the DSB and the Scope of the GDPR

Art. 83 para. 4 lit. a GDPR stipulates that in the event of violations of the provisions of Art. 8, 11, 25 to 39, 42, and 43 GDPR, fines of up to 10,000,000 Euros or, in the case of an enterprise, up to 2% of its total worldwide annual revenue from the preceding financial year may be imposed, depending on which amount is higher.

According to § 22 para. 5 DSG, the jurisdiction for imposing fines on natural and legal persons for violations of the DSG and the GDPR lies with the DSB.

Pursuant to Art. 2 para. 1 GDPR, the regulation applies to the wholly or partially automated processing of personal data as well as to the non-automated processing of personal data that are stored or are intended to be stored in a filing system.

There is no doubt regarding the existence of processing of personal data within the meaning of Art. 4 no. 1 and 2 GDPR. The role of the accused as the controller according to Art. 4 no. 7 GDPR has also never been disputed. Although the managing director named himself in the report pursuant to Art. 33 GDPR, the fact that the managing director made the report on behalf of the accused in his capacity as managing director was already conclusively clarified in the context of the first administrative fine procedure (GZ: D550.829).

As the controller, the accused is subject to the relevant obligations of the GDPR. In the specific case, the accused, as the controller, was subject to the obligation to cooperate with the DSB in the context of the security breach procedure according to Art. 31 GDPR due to the security breach that occurred. This provision constitutes a penalized obligation for controllers according to Art. 83 para. 4 lit. a GDPR and will be examined in more detail below.

3.2.

On the Obligation of Controllers to Cooperate with the DSB

Controllers and processors, and where applicable their representatives, must cooperate with the supervisory authority in fulfilling its tasks upon request according to Art. 31 GDPR. This provision also

constitutes a penalized obligation for controllers according to Art. 83 para. 4 lit. a GDPR. From Art. 31 GDPR, in conjunction with the powers of the supervisory authority under Art. 57 and Art. 58 GDPR, both tolerance and cooperation obligations can be derived. The DSB must monitor and enforce the application of the GDPR for the entire territory of Austria ("in its territory") according to Art. 57 para. 1 lit. a GDPR. This is one of the central tasks of the DSB as the supervisory authority responsible for the Austrian territory. Furthermore, the DSB must fulfill any other tasks related to the protection of personal data according to Art. 57 para. 1 lit. v GDPR. For the fulfillment of these tasks, the DSB is granted both investigative powers and remedial powers (Art. 58 para. 1 and 2 GDPR). The GDPR grants supervisory authorities, among other things, the power to instruct the controller to provide all information necessary for the performance of their tasks (Art. 58 para. 1 lit. a GDPR). From this provision, in conjunction with Art. 31 GDPR, a duty to cooperate arises for the addressees of the norms (see also Recital 82 second sentence GDPR). In the event of a lack of cooperation, the Union legislator therefore introduced the possibility of sanctions in Art. 83 para. 4 lit. a GDPR.

In the present case, the accused, as already mentioned, is to be qualified as a controller according to Art. 4 no. 7 GDPR and thus as the addressee of the relevant obligations of the GDPR. She submitted a data breach notification to the DSB and was subsequently involved as a party in the proceedings. All requests from the DSB were delivered to the accused in the context of the data breach proceedings, as established. Due to the lack of cooperation in this procedure, a penalty notice has already been imposed on the accused. Nevertheless, the accused subsequently failed to respond to the two additional requests for supplementary statements sent during the (here relevant) period of the offense. Thus, she did not cooperate with the DSB as the competent supervisory authority in fulfilling its tasks.

In light of the facts assumed to be proven, the accused also fulfilled the objective side of the offense under Art. 31 GDPR, as she did not cooperate with the DSB in fulfilling its tasks in response to both inquiries.

3.3.

Regarding the subjective side of the offense

The CJEU has explicitly stated regarding the second preliminary question, as already assumed by the Data Protection Authority in its previous case law, that only violations of provisions of the GDPR committed by the controller with fault, i.e., intentionally or negligently, can lead to the imposition of a fine (cf. CJEU of 05.12.2023, C-807/21, para. 68).

Regarding the subjective side of the offense, it should be noted that the requirement of fault for the imposition of a fine under Art. 83 GDPR is to be interpreted autonomously under Union law and, in particular, assessed in light of the case law of the CJEU. Also concerning the preliminary question regarding fault, the CJEU stated that the Union legislator did not grant the Member States any discretion in this regard for national regulations, as the material requirements are conclusively regulated in Art. 83 paras. 1 to 6 GDPR (cf. also CJEU of 05.12.2023, C-683/21, para. 64 et seq.).

Regarding the question of whether a violation was committed intentionally or negligently and can therefore be punished with a fine, the CJEU simultaneously clarified in its aforementioned judgment that such fault is already present if the accused could not be unaware of the unlawfulness of their behavior, regardless of whether they were aware that they were violating the provisions of the GDPR (cf. CJEU C-807/21, para. 76).

Referring to further case law, the CJEU also explicitly clarified that the application of Art. 83 GDPR against legal entities does not require any action or even knowledge on the part of the management body of that legal entity (cf. CJEU judgment of 05.12.2023, C-807/21, para. 77). The responsibility and liability of a controller extends to any processing of personal data carried out by or on behalf of that controller. In this context, the controller must not only take appropriate and effective measures but must also be able to demonstrate that its processing activities are in compliance with the GDPR and that the measures it has taken to ensure this compliance are also effective (cf. CJEU C-807/21, para. 38, referring to Recital 74).

Applied to the present case, this means the following:

First, it should be noted that there were no indications during the investigation that the violations in question were committed by a person acting outside the scope of the business activities and on behalf of the legal entity. The accused also did not make any submissions in this regard, and it is evident from the file that the managing director submitted a data breach notification to the data protection authority on behalf of the accused and subsequently communicated with the responsible caseworker at the data protection authority. As a result, the accused, through its managing director, became aware of the lack of cooperation of the accused in the context of the data breach procedure.

It is irrelevant which specific natural person within the organization of the accused fulfilled the condition of lack of cooperation. According to the CJEU, it is not necessary for the imposition of a fine against a legal entity that the data protection authority identifies a specific natural person who acted in the course of business activities and on behalf of the legal entity in its decision and attributes the actions of that person to the legal entity (cf. CJEU C-807/21, para. 60).

During the course of the investigation, there were no indications that the accused bore no fault in the violation of the applicable administrative regulations. Rather, the accused should have ensured that it responded to the letters sent to it by the data protection authority within the deadline set for it (cf. recently Administrative Court of Vienna judgment of 17.09.2024, W298 2295130-1). This is all the more true as an administrative penalty proceeding had already been conducted against the accused due to a violation of the duty to cooperate.

In light of the CJEU's case law regarding the unlawfulness of its behavior, the accused could not have been unaware, regardless of whether it was aware that it was violating the provisions of the GDPR (cf. CJEU C-807/21, paras. 76 and 77; CJEU C-683/21, paras. 81 and 82 with further references). The accused must, however, be aware that she is committing a violation of the obligation to cooperate as stipulated in Article 31 of the GDPR. This is partly because she is already (legally) convicted due to such a violation and must therefore be aware that violations of the obligation to cooperate are subject to a monetary fine. Furthermore, the requests for supplementary reporting in the data breach procedure underlying the current criminal decision have always pointed out the obligation to cooperate and the fact that a further administrative penalty procedure may be initiated in case of violation of this obligation.

Thus, the accused has at least seriously considered the possibility of committing another violation of the obligation to cooperate but has resigned herself to it (*dolus eventualis*). As a result, there is culpability in the present case in the form of (conditional) intent (Article 83(2)(b) GDPR).

This also fulfills the subjective aspect of the offense.

4.

Regarding the determination of the penalty, the following should be noted:

According to Article 83(1) GDPR, the supervisory authority must ensure that the imposition of fines for violations of the provisions of the GDPR subject to sanctions (Article 83(4), (5), and (6) GDPR) is effective, proportionate, and deterrent in each individual case.

Specifically, Article 83(2) GDPR stipulates that when deciding on the imposition of a fine and its amount, certain criteria must be duly considered in each individual case.

The determination of the penalty within a statutory penalty framework is a discretionary decision that must be made according to the criteria established by the legislator (cf. VwGH 05.09.2013, 2013/09/0106). The criteria to be considered by the Data Protection Authority for the determination of the penalty are conclusively defined in Article 83(2) GDPR.

In the context of penalty assessment, the Data Protection Authority has applied the EDSA guidelines regarding the calculation of fines under the GDPR (cf. EDPB Guidelines 04/2022 on the calculation of administrative fines under the GDPR, Version 2.1 of 24.05.2023 – hereinafter referred to as "Fines Guidelines").

The penalty range in the specific case amounts to up to EUR 10,000,000 according to Article 83(4)(a)

GDPR.

The relevant annual turnover of the accused could not be determined due to lack of cooperation. Therefore, an estimation had to be made by the DSB. The annual financial statement of B*** as of 30.11.2023 shows negative equity. According to the statements of the managing directors in the annex, however, this is covered by hidden reserves in the business property, and there is no over-indebtedness in the sense of § 225(1) UGB. Consequently, the accused is classified into the lowest category of the Fines Guidelines ("Undertakings with a turnover of up until € 2 million"). Through this classification, the size of the company is duly taken into account to ensure, in particular, the proportionality of the fine. The penalty range in the specific case amounts, according to Art. 83 para. 4 GDPR, to a sum of up to EUR 10,000,000 (static penalty range). The dynamic penalty range (2% of annual turnover) does not apply.

In light of the facts assumed to be proven and taking into account the nature, severity, and duration of the violation (Art. 83 para. 1 lit. a GDPR [Note by the editor: obvious editorial error, likely meant Art. 83 para. 2 lit. a GDPR]), the intentionality of the violation (Art. 83 para. 2 lit. b GDPR), as well as the categories of personal data affected by the violation (Art. 83 para. 2 lit. g GDPR), the DSB assumes the severity of the infringement ("Seriousness of the infringement") to be medium ("medium level of seriousness"). In this context, the duration and the (conditional) intentionality of the violation were particularly significant.

Regarding the present facts, the following aggravating factors were additionally considered in the penalty assessment (beyond the criteria already taken into account for determining the severity according to Art. 83 para. 1 lit. a, b, and g GDPR):

- The accused has already committed a violation of the duty to cooperate under Art. 31 GDPR and was therefore previously convicted. This constitutes a relevant prior violation by the accused (Art. 83 para. 2 lit. e GDPR).

Regarding the present facts, the following mitigating factors were additionally considered in the penalty assessment:

- The accused has cooperated in the present administrative penalty proceedings and has now also answered those questions that should have been answered in the context of the duty to cooperate in the security breach proceedings, allowing this procedure to be definitively concluded (Art. 83 para. 2 lit. f GDPR).

In determining the penalty, considerations of special prevention and general prevention may also be included according to the consistent case law of the VwGH (see VwGH 15.5.1990, 89/02/0093, VwGH 22.4.1997, 96/04/0253, VwGH 29.1.1991, 89/04/0061). The imposition of the specific penalty was necessary in terms of special prevention to deter the accused from committing further criminal acts, as the accused was already previously convicted and nevertheless committed another violation. Furthermore, the imposition of a monetary fine was also necessary in the general preventive sense to raise awareness among responsible parties and processors, particularly in connection with their duty to cooperate under Art. 31 GDPR.

The penalty ultimately imposed in the amount of EUR 600 appears, therefore, in light of the realized value of the act, measured against the available penalty range of Art. 83 para. 4 GDPR (here up to EUR 10,000,000) and taking into account the relevant penalty assessment criteria according to Art. 83 para. 2 GDPR, to be appropriate in terms of the act and culpability and is at the lower end of the available penalty range.

An (even) lower amount would no longer meet the criteria for a monetary fine as stipulated in Art. 83 para. 1 GDPR in the present case.